
Suggested Teaching Guideline for
Compliance Audit
PGCP-ITISS February 2026

Duration: 30 Theory hrs

Objective: To introduce the student to Concepts of Security Compliance audit.

Evaluation Method: Theory exam – 80% weightage

List of Books / Other training material

Courseware: No specific courseware for the module, faculty may share some coursematerials.

Reference Books:

- IT Audit, Control, and Security Robert R. Moeller
- IT Auditing: Using Controls to protect Information Assets, Chris Davis/TMH

Session 1 & 2: (4T)

Theory:

- Introduction
- Cyber security Challenges for Organizations
- Compliance Basics
- Types of Security Audit
- Audit Decision Factors
- Security Audit Phases
- Requirements of Internal Audit Team
- Principal of Audits
- Auditor personal abilities

Session 3: (2T)

Theory:

- Security Evaluation
- Evaluation Process
- Evaluation phases
- Assurance – 7 evaluation levels
- Evaluation Methodology

Session 4: (2T)

Theory:

- National Institute of Standards and Technology (NIST) Overview
- Components of Framework
- Use of Framework

Suggested Teaching Guideline for
Compliance Audit
PGCP-ITISS February 2026

Session 5: (2T)

Theory:

- General Data Protection Regulation (GDPR) Overview
- Types of privacy data & GDPR protect
- Key Steps to Ensure GDPR Compliance

Session 6 & 7: (4T)

Theory:

- International Organization for Standardization (ISO) 2700x
- How the standard works
- History of ISO/IEC 27001
- ISO/IEC 27001:2005 domains
- Structure of Standards

Session 8: (2T)

Theory:

- SOx Reports
- SOC Reports - Auditor Process Overview
- SOX COMPLIANCE AND SECURITY CONTROLS

Session 9: (2T)

Theory:

- COBIT framework
- Cobit Components
- Cobit VS ITIL

Session 10: (2T)

Theory:

- Health Insurance Portability and Accountability Act (HIPAA)
- HIPAA regulations
- HIPPA Titles
- HIPAA Rules

Suggested Teaching Guideline for
Compliance Audit
PGCP-ITISS February 2026

Session 11: (2T)

Theory:

- Payment Card Industry Data Security Standard (PCI DSS)
- History of PCI-DSS
- Different Levels of PCI

Session 12: (2T)

Theory:

- Centre for Internet Security (CIS) Critical Security Controls
- CIS Compliance
- CIS Controls
- CIS Benchmarks

Session 13: (2T)

Theory:

- SSE-CMM Project
- History & the Need
- SSE-CMM Overview
- Using the SSE-CMM
- SSE-CMM Pilots

Session 14 & 15: (4T)

Theory:

- ITAA 2008
- Digital Personal Data Protection Act 2023
- Case Studies
- Internal Audit Solution for a Global Bank
- Compliance Audit of Anti-Corruption Regulations
- Can choose as per syllabus